BURP SUITE: REPEATER

TryHackMe Learning & Practical Report

Prepared by: Sofia

Focus: Web Application Security / WAPT Foundations

Platform: TryHackMe

Room: Burp Suite: Repeater

IqraSec Academy - WAPT Internship - Phase 1

1. Executive Summary

This room taught me the Burp Suite Repeater tool: sending one request again and again after changing it, reading the response, and using the Inspector to edit parts of the request. I solved three exercises: adding a custom header, causing a server error with an extreme value and a UNION based SQL injection.

2. Lab Information

Platform	TryHackMe
Room / Lab	Burp Suite: Repeater
Primary Domain	Web Application Security
Purpose	Foundational WAPT practice
Completion	Completed - all room tasks finished
Link	https://tryhackme.com/room/burpsuiterepeater

3. Learning Objectives

- Understand the Repeater layout (request, response, target, Inspector).
- Modify and resend requests.
- Use Inspector to change parameters, cookies and headers.
- Use Repeater to find and exploit a vulnerability.

4. Repeater Layout

Repeater has a Request pane (Pretty, Raw, Hex), a Response pane (with a Render view that shows the page like a browser), a Target field and the Inspector on the right. Inspector gives a simple way to edit request attributes, query parameters, body parameters (shown for POST requests), cookies and headers. History buttons next to Send move back and forward through my changes.

5. Practical 1 - Adding a Header

I captured a request in the Proxy, sent it to Repeater and added the header FlagAuthorised: True. The response then gave the flag.

6. Practical 2 - Server Error

On the products endpoint I changed the product number at the end of the URL to extreme values until the server returned **500 Internal Server Error**. This showed that the application does not validate input.

7. Practical 3 - UNION SQL Injection

On the /about/ page the ID in the URL was injectable. I first found that the query returns eight columns (id, firstName, lastName, pfpLink, role, shortRole, bio, notes). Then used:

0 UNION ALL SELECT notes,null,null,null,null FROM people WHERE id = 1

The CEO has id 1, so the notes column of that row appeared on the page and gave the flag.

8. Evidence

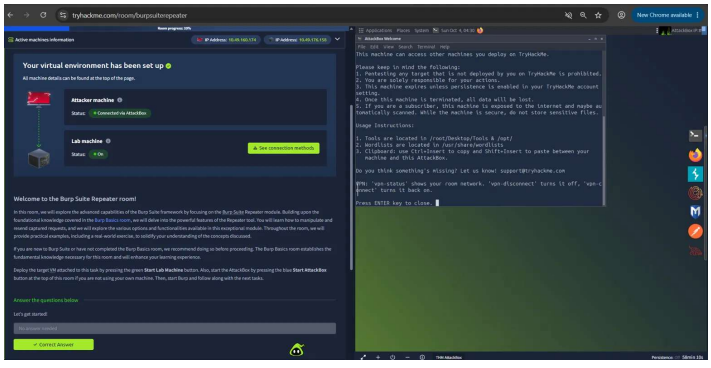


Fig 1 - Room machine and AttackBox started.

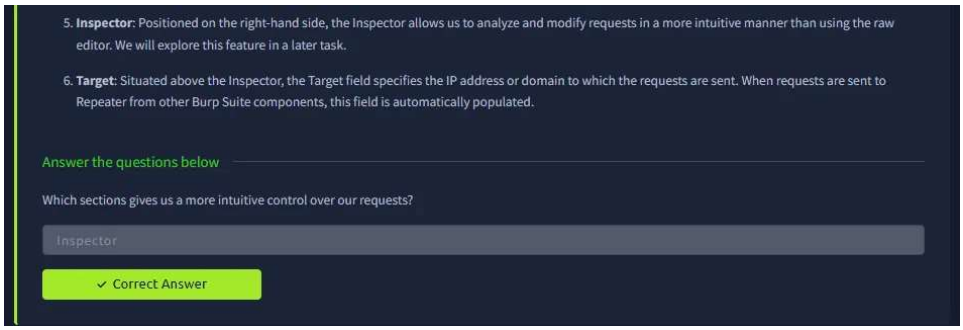


Fig 2 - Inspector and Target questions.

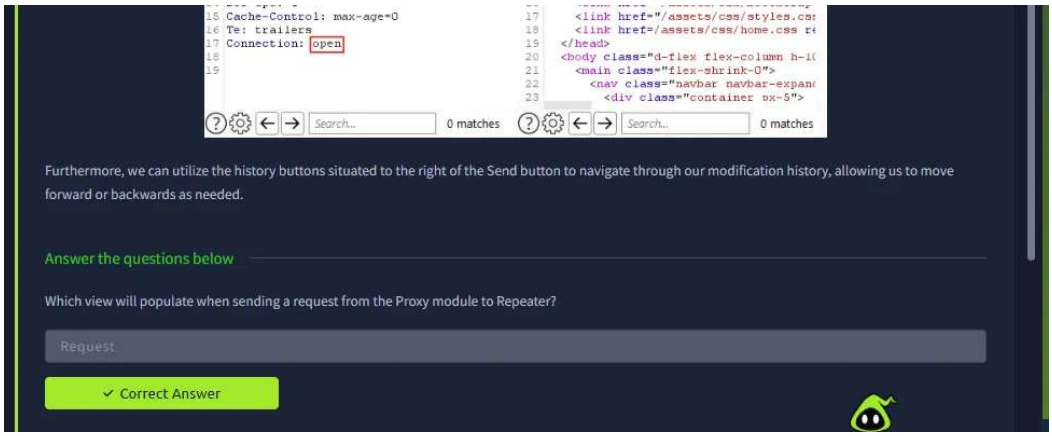


Fig 3 - Request view in Repeater.



Fig 4 - Render option.



Fig 5 - Body Parameters are shown for POST requests.

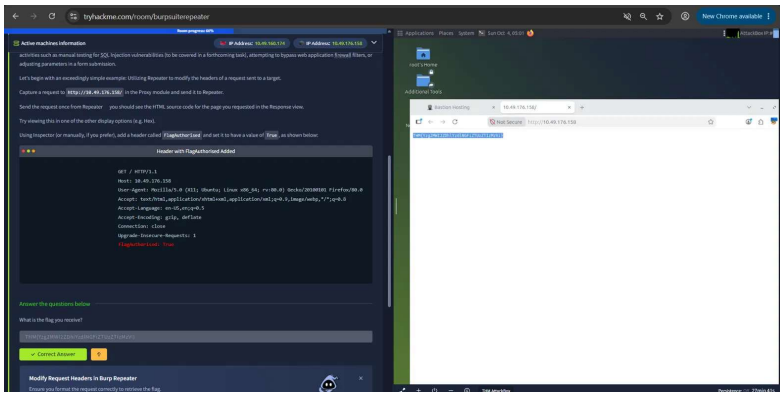


Fig 6 - Adding the custom header in Repeater.

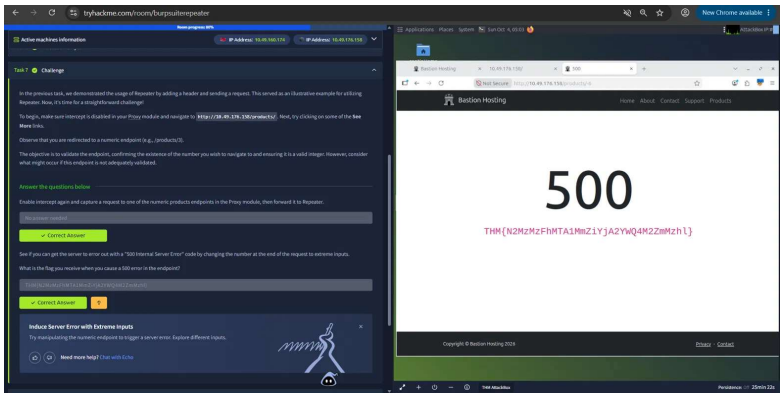


Fig 7 - 500 error caused by an extreme value.

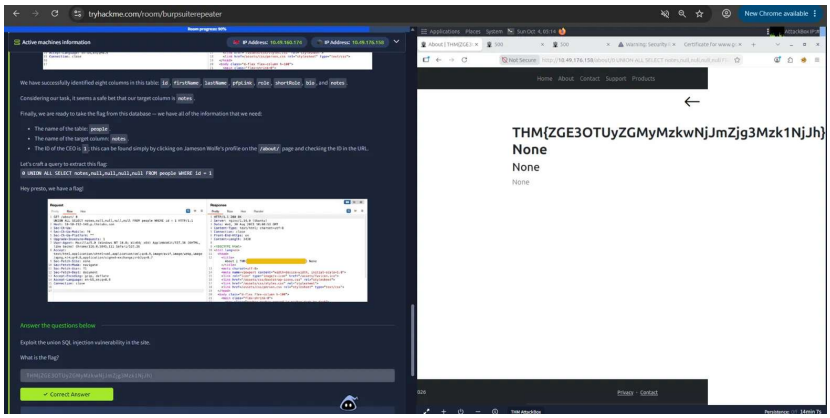


Fig 8 - UNION injection and the flag.

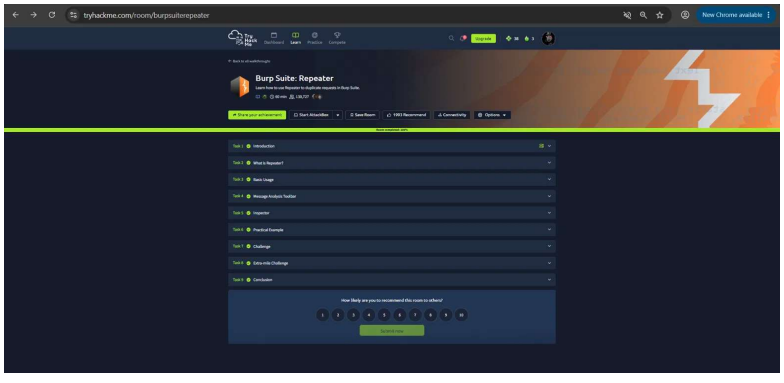


Fig 9 - Room completed.

9. Key Security Takeaways

- Repeater is the best tool for manual testing because I change one thing and see the result.
- A 500 error is a clue that input is handled badly and should be investigated.
- For UNION injection I need the column count first, then the table and column names.
- Always validate and parameterise input on the server.
-

10. Skills Practiced

Area	**Practical understanding gained**
Burp Repeater	Modify and resend requests
Inspector	Edit parameters, cookies and headers
Error testing	Triggering and reading 500 errors
SQL injection	UNION based data extraction

11. What I Would Explore Next

I will use Intruder and Decoder as well and start testing real labs with the Burp Proxy and Repeater together.

12. Conclusion

Repeater became my main tool in this room. Small changes in a header or a number can change how an application behaves, so every input is worth testing.

Completion status: Completed - all room tasks finished.

13. References

TryHackMe: https://tryhackme.com/room/burpsuiterepeater